CARGOBIT SECURITY OPERATIONS

On-Call Operational Runbook

Quick Reference Guide for Security-Layer Incidents
Gateway, Risk-Engine, Mitigation, Audit, Notification

SEV-1 CRITICAL	SEV-2 HIGH	SEV-3 MEDIUM	SEV-4 LOW
5 min response	15 min response	60 min response	24 h response

PURPOSE

This runbook provides immediate, actionable guidance for on-call engineers handling security-layer incidents. Keep this document accessible at all times during on-call shifts. Follow the standard checklist for every incident, then apply specific procedures based on incident type.

Classification: Internal - Operations
Review Cycle: Monthly

Version 1.0
April 2026

1. Grundprinzipien für On-Call

1.1 Ziele

- Sicherheitsvorfälle schnell erkennen
- Schaden minimieren
- Fraud verhindern
- System stabil halten
- Compliance sicherstellen

1.2 On-Call Verantwortlichkeiten

- Alerts entgegennehmen und bestätigen
- Diagnose sofort starten
- Sofortmaßnahmen einleiten
- Eskalieren wenn nötig
- Incident dokumentieren
- Post-Incident-Daten sammeln

1.3 Tools - Immer griffbereit

Tool	Zugang	Zweck
Grafana Dashboard	grafana.cargobit.internal	Metrics, Risk-Level Distribution
Alertmanager	alertmanager.cargobit.internal	Active alerts, Silences
Logs (Kibana/Loki)	logs.cargobit.internal	Gateway, Risk, Mitigation logs
Deployment Dashboard	deploy.cargobit.internal	Recent deployments, Rollback
Runbooks	runbooks.cargobit.internal	Dieses Dokument + Details

Tabelle 1: On-Call Tools

2. Standard-Checkliste (für jeden Incident)

Diese Checkliste wird IMMER abgearbeitet, egal welcher Incident auftritt.

2.1 Sofort (0-2 Minuten)

Schritt	Aktion	Check
1	Alert bestätigen	Alertmanager → Acknowledge
2	Severity prüfen	SEV-1 bis SEV-4
3	Betroffene Services identifizieren	Gateway, Risk, Mitigation, Audit, Notification
4	Traffic-Level prüfen (RPS)	Baseline vergleichen

Tabelle 2: Sofort-Checkliste

2.2 Diagnose (2-10 Minuten)

Prüfung	Tool	Suche nach
Logs	Kibana / Loki	ERROR, WARN, Exception
Latenzen	Grafana	p99 > Baseline
Error-Rates	Grafana	> 0.1% = Warnung, > 1% = Kritisch
Queue-Lag	Grafana	> 2s = Warnung, > 5s = Kritisch
Letzte Deployments	Deploy Dashboard	Änderungen in letzten 2h

Tabelle 3: Diagnose-Checkliste

2.3 Entscheidung (10-15 Minuten)

Frage	Ja →	Nein →
Echter Incident?	Weiter mit Maßnahmen	Alert schließen, False Positive loggen
SEV-1 oder SEV-2?	Sofort eskalieren	Normale Bearbeitung
Known Issue?	Known-Issue-Playbook anwenden	Neue Diagnose starten

Tabelle 4: Entscheidungs-Matrix

2.4 Maßnahmen (15-60 Minuten)

→ Siehe Incident-Typ-spezifische Abschnitte (3-7)

2.5 Recovery

- System stabilisieren (Metrics normalisieren)
- Alerts normalisieren (keine neuen Alerts)
- Audit-Trail prüfen (alle Events geschrieben)
- Queue-Lag $<$ 2 Sekunden

2.6 Dokumentation

- Incident-Report ausfüllen (Template in Confluence)
- Timeline erstellen (von Alert bis Recovery)
- Logs sichern (für Post-Mortem)

3. Incident-Typ A: High-Risk Spike / Fraud-Welle

Severity: SEV-1 (Critical)

3.1 Symptome

- Viele RED-Decisions in kurzer Zeit
- Block-Rate steigt signifikant
- Notification-Service sendet viele High-Risk Alerts
- Support meldet ungewöhnlich viele Tickets

3.2 Diagnose

Check	Grafana Panel	Suche nach
Risk-Level Distribution	Risk Dashboard → Level	RED > 20% of total
Triggered Rules	Risk Dashboard → Rules	Top 10 Rules identifizieren
Geo-Anomalien	Risk Dashboard → Geo	Regionale Häufung
User/Company Cluster	Risk Dashboard → Entities	Gleiche Company, IP-Range

3.3 Sofortmaßnahmen

Maßnahme	Kommando/Aktion	Wann
Strict Mode aktivieren	Gateway Config: strict_mode=true	Bei bestätigter Fraud-Welle
Regel deaktivieren	API: PUT /risk/rules/{id} → active=false	Bei feuernder Regel
Geo-Blockade	Gateway Config: geo_block=["XX"]	Bei regionalem Spike
Benachrichtigung	Slack: #incident-security	Sofort bei SEV-1

3.4 Eskalation

- Security-Engineer: security-oncall@cargobit.eu
- Compliance: compliance@cargobit.eu

3.5 Recovery

- Strict Mode deaktivieren
- Risk-Rules neu trainieren/anpassen
- Fraud-Pattern in Regelwerk aufnehmen

4. Incident-Typ B: Risk-Engine Down / Degraded

Severity: SEV-1 (Critical)

4.1 Symptome

- Gateway Latenz steigt signifikant
- Viele RISK_ENGINE_UNAVAILABLE Errors in Logs
- Circuit-Breaker Status: OPEN
- Risk-Engine Healthcheck: ROT

4.2 Diagnose

Check	Tool/Kommando	Suche nach
Health Check	curl localhost:3003/risk/health	Status != 200
Logs	Kibana: service=risk-engine	Error, Exception, OOM
DB-Latenz	Grafana: DB Dashboard	p99 > 100ms
CPU/Memory	Kubernetes: kubectl top pods	CPU > 80%, Mem > 90%
Recent Deployments	Deploy Dashboard	Änderungen in letzten 2h

4.3 Sofortmaßnahmen

Option	Kommando/Aktion	Wann
Restart	kubectl rollout restart deployment/risk-engine	Bei Service hängend
Rollback	kubectl rollout undo deployment/risk-engine	Nach neuem Deployment
Fail-Safe aktivieren	Gateway Config: fail_safe=block	Bei langem Ausfall

4.4 Eskalation

- Backend-Team Risk-Engine: backend-risk@cargobit.eu
- Platform-Team: platform-oncall@cargobit.eu

4.5 Recovery

- Circuit-Breaker schließen (Status: CLOSED)
- Latenzen normalisieren (p99 < 100ms)
- Audit-Trail prüfen (alle Events geschrieben)

5. Incident-Typ C: Mitigation-Queue Overload

Severity: SEV-2 (High)

5.1 Symptome

- Queue-Lag > 5 Sekunden
- Verzögerte 2FA-Verifikationen
- Verzögerte Delay-Mitigations
- Worker CPU hoch (> 80%)

5.2 Diagnose

Check	Grafana Panel	Threshold
Queue-Lag	Mitigation Dashboard → Lag	> 5s = Kritisch
Worker Count	Mitigation Dashboard → Workers	Vergleich mit Queue-Tiefe
Dead-Letter Queue	Mitigation Dashboard → DLQ	> 100 = Cleanup nötig
Mitigation Types	Mitigation Dashboard → Types	Anteil Delay/2FA/GPS

5.3 Sofortmaßnahmen

Maßnahme	Kommando/Aktion	Priorität
Worker skalieren	kubectl scale deployment mitigation-worker --replicas=10	1 (Sofort)
Priorisierung	Queue Config: priority=2FA>GPS>Delay	2 (Wenn Lag > 10s)
Delay deaktivieren	Mitigation Config: delay_enabled=false	3 (Nur bei Extremsituation)
DLQ cleanup	Admin Tool: dlq-flush	4 (Nach Stabilisierung)

5.4 Eskalation

- Mitigation-Service Team: mitigation-team@cargobit.eu
- Platform-Team: platform-oncall@cargobit.eu

5.5 Recovery

- Queue-Lag < 2 Sekunden
- Worker stabil (CPU < 70%)
- Delay-Mitigations wieder aktiviert

6. Incident-Typ D: Audit-Service Probleme

Severity: SEV-1 (Critical) - Compliance-relevant!

6.1 Symptome

- Audit-Write-Errors in Logs
- Audit-DB Latenz hoch
- Missing Audit Events Alerts
- Hash-Chain Validation Errors

6.2 Diagnose

Check	Tool	Suche nach
DB-Latenz	Grafana: Audit DB Dashboard	p99 > 50ms
Storage	DB Admin: storage check	> 80% full
Write-Errors	Kibana: audit_write_error	> 0 = Kritisch

6.3 Sofortmaßnahmen

Maßnahme	Kommando/Aktion	Hinweis
Restart	kubectl rollout restart deployment/audit-service	Bei Service hängend
DB-Failover	DB Admin Console: Failover	Nur wenn Primary down
Write-Queue flush	Admin Tool: audit-queue-flush	Gepufferte Events schreiben

6.4 Eskalation

- Security-Engineer: security-oncall@cargobit.eu (Compliance-relevant!)
- DB-Team: db-team@cargobit.eu

6.5 Recovery

- Audit-Trail Validierung (alle Events vorhanden)
- Hash-Chain prüfen (Integrität bestätigt)
- Compliance benachrichtigen

7. Incident-Typ E: Notification-Service Failure

Severity: SEV-2 (High)

7.1 Symptome

- Slack Alerts kommen nicht an
- Email Delivery Failures
- Notification Queue wächst

7.2 Diagnose

Check	Tool	Suche nach
Delivery-Latency	Notification Dashboard	p99 > 30s
Queue-Lag	Notification Dashboard	> 60s = Kritisch
Provider-Status	Provider Status Page	Outage bekannt?

7.3 Sofortmaßnahmen

Maßnahme	Kommando/Aktion	Hinweis
Provider wechseln	Notification Config: provider=fallback	Fallback-Slack/Email
Worker skalieren	kubectl scale deployment notification-worker --replicas=5	Bei Queue-Backlog
DLQ prüfen	Admin Tool: notification-dlq-check	Fehlgeschlagene Messages

7.4 Eskalation

- Notification-Team: notification-team@cargobit.eu
- Platform-Team: platform-oncall@cargobit.eu

7.5 Recovery

- Delivery-Rate normal (> 99%)
- Queue-Lag < 2 Sekunden

8. Eskalationsmatrix

Severity	Beschreibung	Max. Reaktionszeit	Eskalation
SEV-1	Fraud-Welle, Risk-Engine Down, Audit-Failure	5 Minuten	Security + Compliance + Platform
SEV-2	Mitigation-Queue Overload, Notification Failure	15 Minuten	Security + Backend
SEV-3	Minor Errors, Slowdowns	60 Minuten	Backend
SEV-4	Non-Critical	24 Stunden	Team Lead

Tabelle 5: Eskalationsmatrix

9. Kommunikationsplan

Severity	Slack Channel	Email an	Besonderheiten
SEV-1	#incident-security	Security, Compliance, Platform	Incident Commander bestimmen
SEV-2	#incident-backend	Backend Team	Reguläre Updates
SEV-3	#dev-ops	-	Ticket erstellen
SEV-4	-	-	Nur Ticket, kein Channel

Tabelle 6: Kommunikationsplan

10. Post-Incident Anforderungen

Zeitrahmen	Aufgabe	Verantwortlich
24h	Timeline erstellen	On-Call Engineer
24h	Root Cause identifizieren	On-Call + Team
24h	Impact Assessment	On-Call Engineer
48h	Fix implementieren	Entsprechendes Team
48h	Regression Tests	QA Team
72h	Post-Mortem Meeting	Team Lead
72h	Lessons Learned dokumentieren	On-Call Engineer
72h	Risk-Rules aktualisieren (falls nötig)	Security-Engineer

Tabelle 7: Post-Incident Checkliste

Key Contacts

Team	Email	Slack
Security On-Call	security-oncall@cargobit.eu	#security-oncall
Backend On-Call	backend-oncall@cargobit.eu	#backend-oncall
Platform On-Call	platform-oncall@cargobit.eu	#platform-oncall
Compliance	compliance@cargobit.eu	#compliance
Incident Commander	incident-commander@cargobit.eu	#incidents

Tabelle 8: Key Contacts